Republic of the Philippines
CAVITE STATE UNIVERSITY
Don Severino de las Alas Campus
Indang, Cavite

COLLEGE OF ENGINEERING AND INFORMATION TECHNOLOGY
Department of Information Technology

Name: _____ Student No.: _____
Course / Yr. / Sec.: _____ Date: _____

Portfolio #5: End Of Midterm Review

Objectives

- To evaluate the balance of the CIA Triad within a quantitative risk management framework.
- To analyze the intersection of Philippine Cyberlaws (RA 10173 and RA 10175) regarding data breaches.
- To differentiate the strategic functions of Enterprise and Issue-Specific Security Policies.

Instructions

Score: ___ / 100

- Answer the following three (3) theoretical reflection and application items based on the lessons covering the CIA Triad, Legal Issues, Risk Management, and Security Frameworks.
- **Scoring Penalties:**
    - An incorrect answer or fundamental conceptual error will result in a **-10 point** deduction from the item score.
    - Failure to meet the specific requirements of a criterion (e.g., missing a required calculation or legal citation) will result in a **-5 point** deduction.
    - Empty answers or those showing no attempt to reach the criterion earn **0 points**.
- **Submission:** Save your file as Surname_Portfolio6.pdf and submit via the designated asynchronous bin.

1. Risk Assessment and Strategy (40 Points)
A local financial firm identifies that their main database, valued at **Php 2,500,000 (Asset Value)**, is at risk of a ransomware attack. Historical data suggests an **Exposure Factor (EF) of 40%** per incident and an **Annualized Rate of Occurrence (ARO) of 0.2** (once every five years).

- **a.** Calculate the **Annualized Loss Expectancy (ALE)** for this threat.
- **b.** The firm is considering a security suite that costs **Php 150,000 per year**. Based on a **Cost-Benefit Analysis (CBA)**, should they implement the control?
- **c.** Justify your answer by selecting the most appropriate **Risk Control Strategy** (Avoidance, Transference, Mitigation, or Acceptance) as defined in Lesson 5.

Answer:

2. Legal and Ethical Taxonomy (40 Points)
An individual discovers a vulnerability in a government website. Without obtaining written permission, they access the system to "test" the security but do not steal or destroy any data. They later publicly disclose the flaw to force the agency to fix it.

- **a.** Based on the **Hacker Taxonomy**, what "Hat" is this individual wearing?
- **b.** Is this act legal in the Philippines? Cite the specific **Republic Act (RA)** and the specific **offense category** (e.g., Offenses against confidentiality, integrity, and availability) from the syllabus that applies here.
- **c.** Explain why "intent" (even if not malicious) does not exempt the individual from liability under **RA 10175**.

Answer:

3. Framework Application (20 Points)
Your organization decided to adopt the **NIST Cybersecurity Framework (CSF)**. You are tasked with improving the **"Protect"** and **"Detect"** functions.

- Briefly describe **one (1) specific technical control** for the "Protect" function and **one (1) specific tool or practice** for the "Detect" function based on Lesson 6.2. Explain how these two work together to support the **Defense in Depth** architecture.

Answer:

Rubric

Criterion	Excellent (Full Points)	Needs Improvement (Score -5)	Incorrect/Failure (Score -10 or 0)	Score
Content Accuracy & Technical Depth (40 pts)	Calculations are exact; legal RAs are cited correctly; technical terms are used accurately.	Minor calculation errors or imprecise use of technical terms.	Fundamental misunderstanding of formulas or laws (-10); No attempt (0).	/40
Critical Thinking & Analysis (40 pts)	Analysis connects theory to the scenario; justifications for strategies are logical and evidence-based.	Analysis is generic or lacks a clear connection to the provided scenarios.	Logic is flawed or contradicts established security principles (-10).	/40
Organization & Clarity (20 pts)	Responses are clear, concise, and follow the required structure.	Responses are disorganized or difficult to follow.	Response is illegible or irrelevant to the question.	/20
TOTAL				**/100**